تقرير المرحلة 1 — CD-006 (البنود 1–6)

الحقل	القيمة
المشروع	نظام تقييم الأداء الوظيفي (Employee Evaluation)
الوحدة	C2/C3 — المستخدمون والأدوار والصلاحيات (RBAC)
الكيان المكلَّف	كبير المطورين
المرحلة	**المرحلة 1 — البنود 1–6 (اكتمال كامل)**
التاريخ	2026-09-23
الحالة	**مكتملة (6/6) — جاهزة للاعتماد**
التقرير الشامل	INDEX.md + 99_Master_Handover_Report.md_00
سجل التنفيذ الكامل	CD-006_IMPLEMENTATION.md

---

1. ملخص تنفيذي

نُفِّذت **البنود الستة الأولى** من المرحلة 1 للوحدة C2/C3 (المستخدمون والأدوار والصلاحيات) وفق خطة CD-006 المعتمدة، بثلاث ركائز: **شيفرة المصدر في جذر مستودع التطبيق**، و**ترحيلات بيانات موثقة** في /database/migrations، وإثبات **حي عبر HTTP** لكل بند. كل البنود مغلقة بخط إغلاق إلزامي في CD-006_IMPLEMENTATION.md وعدّلها في CHANGELOG.md.

النتيجة: المرحلة 1 مكتملة؛ قاعدة البيانات نظيفة (4 مستخدمين حقيقيين، بلا بيانات اختبار)؛ نموذج RBAC محصّن ضد تصعيد الصلاحيات وحماية آخر مدير نشط؛ اختبارات الوحدة بلا انحدار.

---

2. نطاق المرحلة 1 وحدودها

البند	العنوان	الحالة
1	تنظيف بيانات الاختبار (بقايا CD-004)	✅ مكتمل
2	إصلاح شاشة إنشاء المستخدم (admin/users/create.php)	✅ مكتمل
3	حماية آخر مدير نظام نشط	✅ مكتمل
4	تصحيح صلاحيات RBAC (Manager)	✅ مكتمل
5	تصحيح صلاحيات Staff (إزالة branches.manage)	✅ مكتمل
6	منع تصعيد الصلاحيات في updatePermission	✅ مكتمل

خارج النطاق (محوَّل للوحدة/المرحلة التالية): ـ الشاشة التالفة A2_Users_Roles_Unit_Documentation (§ النطاق) لا تشمل إصلاح بقية الشاشات. ـ الدين التقني والاكتشافات خارج النطاق (OOS-1…OOS-8) موثّقة في CD-006_OUT_OF_SCOPE.md.

---

3. التنفيذ التفصيلي لكل بند

بند 1 — تنظيف بيانات الاختبار

- حذف **58 حساب اختبار** (نمط %@cd004 / %_test / %.test.local) + صف عضوية يتيم وحيد في user_roles.
- خطة: نسخة احتياطية كاملة قبل التنفيذ، ثم ترحيل موثّق بسجل تدقيق USER_CLEANUP_TEST_DATA في audit_logs.
- **الإثبات:** users=4، user_roles=4، بلا صفوف يتيمة، سجلا تدقيق 682/683. ✅

بند 2 — إصلاح شاشة إنشاء المستخدم

- إعادة كتابة كاملة لـadmin/users/create.php (كان يحوي markup باني القوالب المعطوب الذي يجعل الشاشة غير صالحة).
- النموذج الجديد: username/email/password/password_confirm/role_id/employee_id + CSRF + POST /admin/users.
- **الإثبات:** Live HTTP — GET 200 بكل الحقول والقوائم (بلا أثر باني القوالب)؛ POST ينشئ مستخدمًا فعليًا بتدقيق USER_CREATE. تنظيف لاحق ✅ users=4. ✔

بند 3 — حماية آخر مدير نظام نشط

- منع حذف/تعليق/خفض آخر مدير نشط (UserController::destroy/toggleStatus/updateRole) عبر isLastActiveAdmin().
- warnIfSingleActiveAdmin() تُنبّه الأدمن عند الهبوط إلى مدير واحد، مع سجل تدقيق LAST_ADMIN_PROTECTED.
- **الإثبات:** Live HTTP بجلسة قديمة Admin مهجورة — المنع يعمل عبر المخدِعات الثلاثة مع رسائل تمييز، والمدير النشط يبقى محميًا (users=4، sysadmin active Admin). ✔

بند 4 — تصحيح صلاحيات RBAC) Manager)

- إضافة الصلاحيات المفقودة (evaluations.create.team + evaluations.view.team ids) ومنح Manager الصلاحيات الثلاث 39/40

evaluations.view.team/evaluations.create.team/reports.view.team عبر ترحيل item4_manager_rbac.sql بسجل PERMISSION_ADDED. ـ مشغّل permissions_version رفع نسخة Manager تلقائيًا (إبطال ذكي للجلسة). ـ **الإثبات:** DB + تطبيقي (Live + User::getUserPermissions) HTTP — Manager يملك الصلاحيات الثلاث بالضبط، بقية الأدوار بلا تغيير. ✅

بند 5 — تصحيح صلاحيات Staff (إزالة branches.manage)

- إزالة (branches.manage id14) من دور Staff ومنح (branches.view id13) بدلاً منه — سدّ ثغرة أمنية كانت تمنح إدارة الفروع لموظف عادي.
- ترحيل item5_staff_branches.sql بسجل PERMISSION_REMOVED + رفع permissions_version.

- **الإثبات:** Staff = {branches.view, departments.view} بلا branches.manage؛ تطبيقي عبر User::getUserPermissions؛ audit موجود. ✅

بند 6 — منع تصعيد الصلاحيات في updatePermission

- إلزام Auth::isAdmin() داخل RoleController::updatePermission (تعديل الصلاحيات = Admin فقط).
- منع منح صلاحية لا يملكها المُنفِّذ؛ التحقق من وجود الصلاحية؛ سجل تدقيق غني بـold/new وpermission_name وactor_id.
- **الإثبات:** Live HTTP — Admin يضيف/يزيل (200)؛ النموذج C (منح صلاحية لا يملكها) ✅ 403؛ الحالة D (صلاحية غير موجودة) ✅ 404؛ غير-403 → Admin؛ Admin محمي من تعديل صلاحياته. ✅

---

4. حالة Git

مستودع التطبيق (جذر المشروع)

الحقل	القيمة
الفرع	master
Commit الـ baseline	6cfa863 — chore(git): CD-006 baseline — أنسنة Git بعد المرحلة 1 (قبل البدء بالبند 7)
الحالة	نظيف (clean)، من دون gitlink للتسليم
.gitignore	في جذر التطبيق — يستثني vendor/config/storage/backups والسكربتات المؤقتة ويبقي الترحيلات متتبَّعة

مستودع التسليم (CD-001_delivery/)

الحقل	القيمة
الفرع	master
آخر Commit	33b1a0b — chore(A2): إغلاق البند 6
الوثائق	15 وثيقة رئيسة + فهارس + سجل التغيير + الترحيلات المنسوخة

القرار المنفَّذ (اعتماد المستشار): لا نقل للـ Commits القديمة إلى مستودع التطبيق — baseline جديد يوثق حالة الشيفرة بعد المرحلة 1؛ مستودع التسليم يحتفظ بالتاريخ التفصيلي والوثائق.

---

5. ضمان الجودة والإثبات

الفئة	النتيجة
php -l (كل الملفات المعدّلة)	نظيف — لا أخطاء صياغة ✅
اختبارات الوحدة (Core)	بلا انحدار — خط الأساس المعروف محفوظ
Live HTTP (كل بند)	أُثبتت فعليًا بجلسة/حسابات مؤقتة نُظّفت بعد كل بند ✅
تنظيف البيانات	بعد كل بند عاد users=4/user_roles=4 — الحسابات المؤقتة دُمرت ✅

6. الاكتشافات خارج النطاق (ملخص)

- **OOS-1…OOS-8** موثّقة كاملة في `CD-006_OUT_OF_SCOPE.md` (وهي لا تمنع إغلاق المرحلة 1).
- أبرزها: `config/database.php` مكوّن محلي حساس، سكربت `run_migration.php` الجذري غير مطلوب للمستقبل، محوّل PDF (mPDF RTL بخط Cairo) مؤقت خارج كود التطبيق، والفروق البيئية في Database/Helpers tests. - الدين التقني المحوَّل إلى المرحلة 2 / CD-007 موثق في `CD-006_IMPLEMENTATION.md` و`CD-006_OUT_OF_SCOPE.md`.

---

7. التوصية والخطوة التالية

التوصية: اعتماد المرحلة 1 (البنود 1–6) وإصدار إذن بدء المرحلة 2 (البنود 7–12 + OOS-8) وفق الخطة المعتمدة.

خط الإغلاق الإلزامي: المرحلة 1 مكتملة — التقرير أعلاه — الإثبات في `CD-006_IMPLEMENTATION.md`.

أُعدّ هذا التقرير وفق تنسيق الوثائق الرسمية لوحدة C2/C3. التوقيع: كبير المطورين — 2026-09-23.